

Name: Salau Oseni

Center: Cyberdev

Instructor: ENG, ABD Tvet Instructor

Course: Cyber security/Networking

Exam: Final Exam

Question 1. You are given a domain **example.com**.

(1a) How would you discover its subdomains using tools like Recon-ng or Amass?

Answer: a subdomain can be discover with the use of tools called **sublist3r**. sublist3r is an effective tool for finding subdomain of a target domain.

Instructions

Open your Terminal in Kali linux

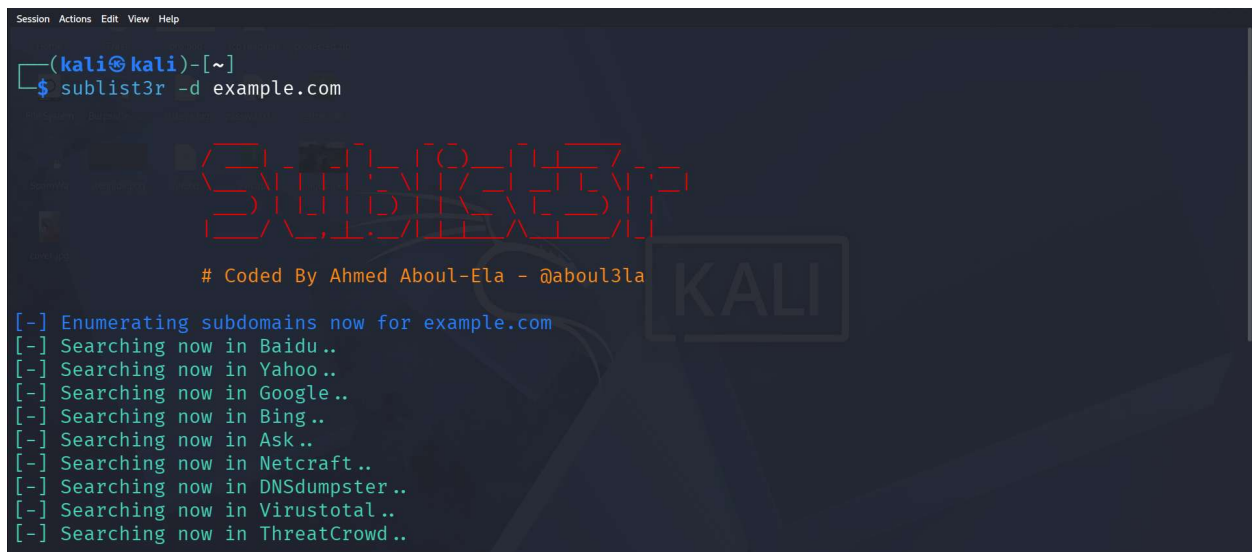
Use the sublist3r command follow by the target domain

Command Syntax

Sublist3r -d <target domain>

Example:

Sublist3r -d Example.com



```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ sublist3r -d example.com

  SUBLIST3R
  # Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for example.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
```

```
[~] Total Unique Subdomains Found: 7
AS207960 Test Intermediate - example.com
www.example.com
dev.example.com
m.example.com
products.example.com
support.example.com
m.testexample.com
```

(1b) How would you identify the IP address and hosting provider of a target website?

Answer

With the use of nslookup a target website IP address and hosting provider will be identify

Instructions

Open your Terminal in Kali linux

Use the nslookup command follow by the target domain

Command Syntax

Nslookup <target domain>

Example

Nslookup Example.com

```
(kali㉿kali)-[~]
$ nslookup example.com
Server:      10.0.2.3
Address:     10.0.2.3#53

Non-authoritative answer:
Name:   example.com
Address: 104.18.27.120
Name:   example.com
Address: 104.18.26.120
Name:   example.com
Address: 2606:4700::6812:1b78
Name:   example.com
Address: 2606:4700::6812:1a78
```

(1c) What tool would you use to gather employee emails from a company domain?

Answer: theHarvester

```
Session Actions Edit View Help
*
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****
[*] Target: example.com
[*] Searching Baidu.
[*] No IPs found.
[*] Emails found: 1
test@example.com
[*] No people found.
[*] Hosts found: 1
external.example.com
```

In this case this command `theHarvester -d example.com -l 100 -b baidu` was used to search target domain `example.com` and we get no IPs found, 1 email found which is test@example.com and 1 host found which is `external.example.com`

Key Aspects of theHarvester:

- **Functionality:** Gathers emails, subdomains, hosts/IPs, and employee names.
- **Sources:** Searches Google, Bing, LinkedIn, Twitter, Baidu, Shodan, and Hunter.io.
- **Usage:** It is a command-line tool, typically pre-installed on Kali Linux.
- **Basic Command:** `theHarvester -d example.com -l 100 -b Baidu` (searches 100 results on Baidu for Example.com)
- **Help:** use `theHarvester -h` for help on how to make use of it tags

(1d) How can DNS misconfiguration lead to vulnerabilities?

Answer:

- **Subdomain Takeover (Dangling CNAMEs):** When a DNS record (CNAME) points to a deleted or abandoned external service (e.g., AWS S3 bucket, GitHub Pages), an attacker can claim that service and take control of the subdomain to host phishing sites or malware.

- **DNS Hijacking and Redirection:** If a DNS registrar account is compromised or records are poorly managed, attackers can change IP addresses to redirect traffic to malicious servers, capturing sensitive credentials.
- **Weak Email Protection (SPF/DMARC/DKIM):** Improperly configured DNS records for email (like using `+all` in SPF) allow attackers to spoof company domains, making phishing emails appear legitimate and bypass spam filters.
- **Open Zone Transfers (AXFR):** Improperly secured DNS servers allowing zone transfers (AXFR) permit attackers to download the entire DNS zone file, revealing internal network infrastructure, server names, and private IP addresses.

Question 2

(2a) Using Nmap, how would you:

- Scan all open ports?
- Detect OS version?
- Run default scripts?

Answer:

(2ai) Scan all open ports by using this command : `Nmap -p- <target IP address>`

Example

`Nmap -p- 198.54.114.135`

```
(kali㉿kali)-[~]
$ nmap -p- 198.54.114.135
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 06:01 -0400
Stats: 0:02:26 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 49.40% done; ETC: 06:06 (0:02:29 remaining)
Nmap scan report for server193-1.web-hosting.com (198.54.114.135)
Host is up (0.074s latency).
Not shown: 65531 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
443/tcp   open  https
587/tcp    open  submission

Nmap done: 1 IP address (1 host up) scanned in 300.19 seconds
```

(2aii) detect OS version with this command `nmap -O <target IP address>`

(2iii) run default scripts with this command `nmap -Sc <target IP address>`

(2b) What does this command do? `nmap -sS -sV -O 192.168.1.1`

- `-sS` is for TCP SYN scan
- `-sV` is for service detection
- `-O` is for OS detection

(2c) How would you enumerate SMB shares on a target machine?

Answer : `enum4linux -S <target_ip>`

Example : `enum4linux -s 198.54.114.135`

(2d) What is the difference between **TCP SYN scan** and **TCP Connect scan**?

Answer

- **TCP SYN Scan:** Sends a SYN packet, receives a SYN/ACK, then sends a RST (Reset) packet to immediately close the connection.
- **TCP Connect Scan:** Completes the full three-way handshake (SYN, SYN/ACK, ACK) and then closes the connection, using the operating system's `connect()` system call.

Question 3a: What is a vulnerability scanner? Name one (e.g., Nessus).

Answers:

A vulnerability scanner is an automated security tool that inspects networks, applications, and cloud environments to identify security weaknesses, such as unpatched software, misconfigurations, and known vulnerabilities. It compares system configurations against a database of known flaws (e.g., CVEs) to provide reports and remediation recommendations.

One widely used example is **Tenable Nessus**, a professional tool used for vulnerability assessments and penetration testing to proactively secure IT infrastructure

(3b) After scanning a system, you find port 21 open.

What vulnerability might you check for?

Answer

An open port 21 indicates an active **FTP (File Transfer Protocol)** service, which is frequently vulnerable due to unencrypted, plaintext communication. Key vulnerabilities to check include **Anonymous Login** (allowing unauthorized file access), **weak/default credentials** (susceptible to brute-force), **directory traversal** (escaping the root directory), and known **service version exploits**

(3c) What is CVE and why is it important?

Answer

Common Vulnerabilities and Exposures (CVE) is a standardized, publicly available dictionary of known cybersecurity vulnerabilities in software and hardware. Maintained by the MITRE Corporation, it assigns a unique ID (e.g., CVE-2024-1234) to each flaw, allowing security teams to share data, prioritize fixes, and identify risks consistently.

Why CVE is Important:

- **Common Language:** Enables security professionals, researchers, and vendors to refer to the exact same issue, reducing confusion in threat intelligence and patching.
- **Prioritization:** Helps organizations quickly evaluate risks based on CVE ID and severity scores (CVSS), allowing them to prioritize fixing critical vulnerabilities first.
- **Efficient Vulnerability Management:** Powers vulnerability scanners and security tools to automatically detect and identify, through a unique ID, known security gaps in systems.
- **Standardization:** Provides a universal framework for cataloging, ensuring that different security databases link to the same information.

Question (4a) You discover a login page vulnerable to brute force.

Which tool can you use? (Hint: Hydra, John the Ripper)

Answer: Hydra

(4b) Explain how SQL Injection works in a login form.

Answer:

SQL Injection (SQLi) in a login form works by inserting malicious SQL code into input fields (username/password), tricking the backend database into executing unintended commands. Instead of authenticating, the database receives a manipulated query that bypasses password checks, often granting unauthorized administrative access.

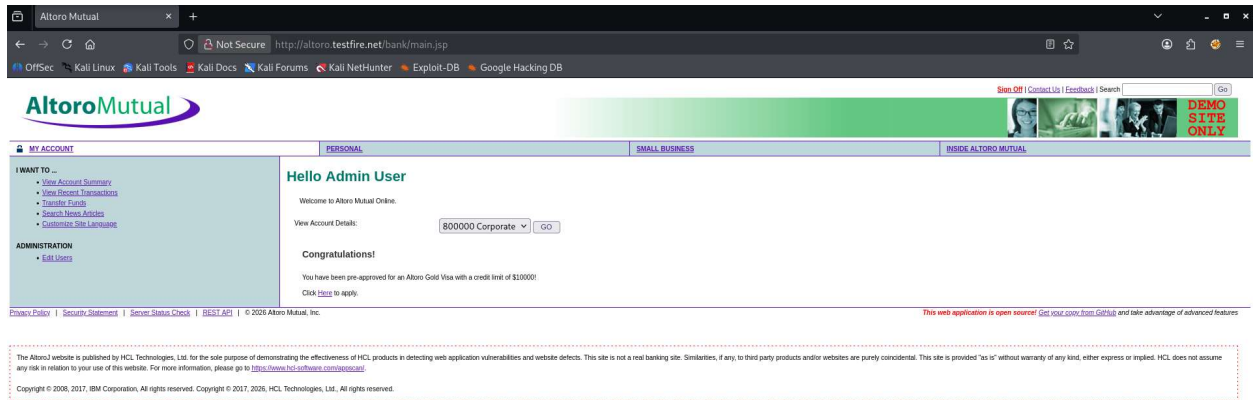
(4c) What would this input do? Hint: **Goal:**

Answer

Goal

(4d) Test login form (Any Vulnerabilities Application used in class)

Answer



1. Authentication Bypass (Log in as Admin)

The goal is to manipulate the backend SQL query to always return a true result, allowing access without a valid password.

- **Target Page:** `http://testfire.net`
- **Username Payload:** `admin' --`
- **Password:** (Any value, e.g., `password`)

Use Burp Suite:

1. Intercept request
2. Modify input

Answer

Time	Type	Direction	Method	URL	Status code	Length
07:51:14 6 Apr 2...	HTTP	→ Request	GET	https://www.google.com/search?q=england&sa_esv=eb434db3e8c774e&xsrf=ANL-n4CTpFRBjSEH5b0NEHwPCE3ig3A1775476255482&source=hp&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:15 6 Apr 2...	HTTP	→ Request	POST	https://www.google.com/gen_204?atyp=i&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:17 6 Apr 2...	HTTP	→ Request	POST	https://www.google.com/gen_204?atyp=i&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:35 6 Apr 2...	HTTP	→ Request	POST	https://play.google.com/log/hasfast=true&auth=SAPSIDHASH+6ed33c4a80c714b3aa0ac5f159943e81cccf05+SAPSIDPHASH+6ed33c4a80c714b3aa0ac5f159943e81cccf05+SAPSID3PHASH+6ed33...		

Request

PrettyRawHex

1 GET /search?q=england&sa_esv=eb434db3e8c774e&xsrf=ANL-n4CTpFRBjSEH5b0NEHwPCE3ig3A1775476255482&source=hp&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd... 200 OK application/javascript 1024 B

2 Host: www.google.com

3 Cookie: AEC-Aa3a5dDIP4j6-K18dk0_SF2N-x2fZFNWC2TqkL8E_fpfj9q09LA; NID=530=gds_HOTRKA3p3hHtYrSr2v_40yHxZgT1owF9S0uPKvqVig6PKLh93BW11BONwDmTqFLqWw8G380avOK7e70-7-LZ6dNL3oDjnmUwL1Jj1NgpEquFPAbvGRDPahgtJnthAsAe1dwV0vAn55W_VXSwAV-RtTBn...

Inspector

Request attributes

Request query parameters

Request body parameters

Request cookies

Request headers

Time	Type	Direction	Method	URL	Status code	Length
07:51:14 6 Apr 2...	HTTP	→ Request	GET	https://www.google.com/search?q=england&sa_esv=eb434db3e8c774e&xsrf=ANL-n4CTpFRBjSEH5b0NEHwPCE3ig3A1775476255482&source=hp&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:15 6 Apr 2...	HTTP	→ Request	POST	https://www.google.com/gen_204?atyp=i&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:17 6 Apr 2...	HTTP	→ Request	POST	https://www.google.com/gen_204?atyp=i&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:35 6 Apr 2...	HTTP	→ Request	POST	https://play.google.com/log/hasfast=true&auth=SAPSIDHASH+6ed33c4a80c714b3aa0ac5f159943e81cccf05+SAPSIDPHASH+6ed33c4a80c714b3aa0ac5f159943e81cccf05+SAPSID3PHASH+6ed33...		
07:53:54 6 Apr 2...	HTTP	→ Request	POST	https://ads.mozilla.org/v1/ads		

Request

PrettyRawHex

1 GET /search?q=career&sa_esv=eb434db3e8c774e&xsrf=ANL-n4CTpFRBjSEH5b0NEHwPCE3ig3A1775476255482&source=hp&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd... 200 OK application/javascript 1024 B

2 Host: www.google.com

3 Cookie: AEC-Aa3a5dDIP4j6-K18dk0_SF2N-x2fZFNWC2TqkL8E_fpfj9q09LA; NID=530=gds_HOTRKA3p3hHtYrSr2v_40yHxZgT1owF9S0uPKvqVig6PKLh93BW11BONwDmTqFLqWw8G380avOK7e70-7-LZ6dNL3oDjnmUwL1Jj1NgpEquFPAbvGRDPahgtJnthAsAe1dwV0vAn55W_VXSwAV-RtTBn...

Inspector

Request attributes

Protocol

Name

Method

Path

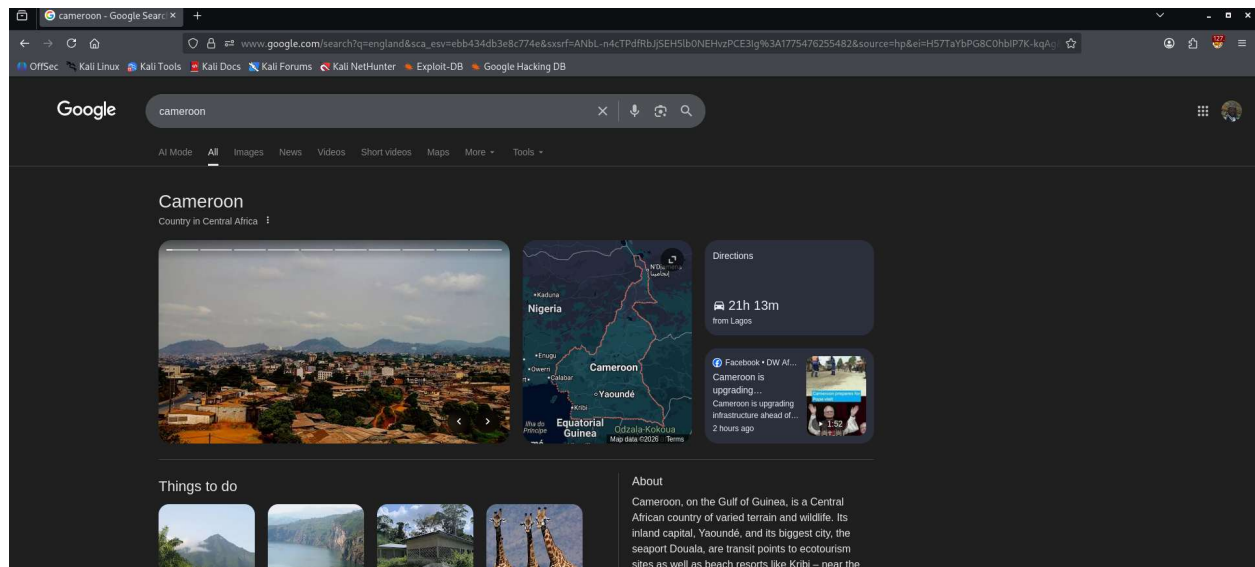
Request query parameters

Request body parameters

Request cookies

Request headers

Time	Type	Direction	Method	URL	Status code	Length
07:51:14 6 Apr 2...	HTTP	→ Request	GET	https://www.google.com/search?q=england&sa_esv=eb434db3e8c774e&xsrf=ANL-n4CTpFRBjSEH5b0NEHwPCE3ig3A1775476255482&source=hp&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:15 6 Apr 2...	HTTP	→ Request	POST	https://www.google.com/gen_204?atyp=i&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:17 6 Apr 2...	HTTP	→ Request	POST	https://www.google.com/gen_204?atyp=i&ei=H57TaYbPG8C0hBP7K-kqAg61f1sig=AFd...		
07:51:35 6 Apr 2...	HTTP	→ Request	POST	https://play.google.com/log/hasfast=true&auth=SAPSIDHASH+6ed33c4a80c714b3aa0ac5f159943e81cccf05+SAPSIDPHASH+6ed33c4a80c714b3aa0ac5f159943e81cccf05+SAPSID3PHASH+6ed33...		
07:53:54 6 Apr 2...	HTTP	→ Request	POST	https://ads.mozilla.org/v1/ads		

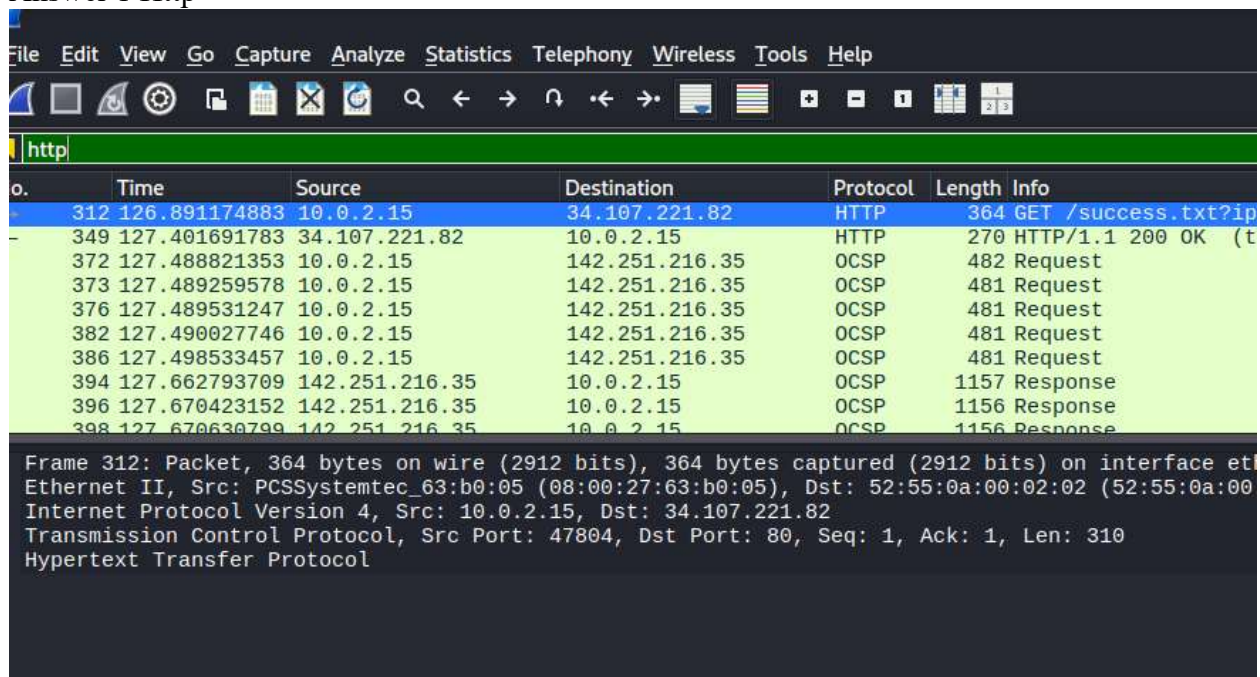


Question 5

5. Use Wireshark and TShark to capture packet and compare the result.

1. Http
2. Source IP
3. Destination IP

Answer 1 Http



2 Source IP address

No.	Time	Source	Destination	Protocol	Length	Info
308	126.735868810	142.251.154.119	10.0.2.15	TLSv1.3	2440	Application Data
309	126.735889834	10.0.2.15	142.251.154.119	TCP	54	59296 → 443 [ACK] Seq=1900 Ack=5187 Win=65535 Len=0
310	126.751428388	10.0.2.15	142.251.154.119	QUIC	89	Handshake, DCID=e091e41975252a64, SCID=efe24b
311	126.889384993	10.0.2.15	142.251.155.119	QUIC	128	Handshake, DCID=e2d101463f85a2a8, SCID=142770
312	126.891174883	10.0.2.15	34.107.221.82	HTTP	364	GET /success.txt?ip=4 HTTP/1.1
313	126.891648744	34.107.221.82	10.0.2.15	TCP	60	80 → 47894 [ACK] Seq=1 Ack=311 Win=65535 Len=0
314	127.081885627	10.0.2.15	10.0.2.3	DNS	92	Standard query 0x976d A www.kwarastatepolytechnic.edu.ng
315	127.087943066	10.0.2.15	10.0.2.3	DNS	70	Standard query 0xc186 A o.pki.goog
316	127.088260867	10.0.2.15	10.0.2.3	DNS	70	Standard query 0x5dbb AAAA o.pki.goog
317	127.184865085	10.0.2.3	10.0.2.15	DNS	150	Standard query response 0x976d A www.kwarastatepolytechnic.edu.ng QNAME kwarastatepolytechnic.edu.ng QTYPE A RRSIG 142 148 76 29
Frame 312: Packet, 364 bytes on wire (2912 bits), 364 bytes captured (2912 bits) on interface eth0, id 0000 Ethernet II, Src: PCSSystemtec 63:b8:05 (08:00:27:63:b8:05), Dst: 52:55:0a:00:02:02 (52:55:0a:00:02:02) Internet Protocol Version 4, Src: 10.0.2.15, Dst: 34.107.221.82 Transmission Control Protocol, Src Port: 47804, Dst Port: 80, Seq: 1, Ack: 1, Len: 310 Hypertext Transfer Protocol						
0000 52 55 0a 00 02 02 08 00 27 63 b8 05 08 00 45 00 R U C E 0010 01 5e 0b ef 48 00 48 06 7c de 0a 00 02 0f 22 6b A . @ . [. k 0020 dd 52 ba bc 80 50 f1 b4 14 47 02 7c b8 02 50 18 R . . P . . G [. . P 0030 fa f0 0d 1d 00 00 47 45 54 20 2f 73 75 63 63 65 G E T / s u c c e s s 0040 73 73 2e 74 70 74 3f 69 70 76 3a 20 48 54 54 50 s s . t x t / 1 p v 4 H T T P 0050 2f 31 2e 31 0d 0a 48 6f 73 74 3a 20 64 65 74 65 / 1 . 1 H o s t : d e t e 0060 63 74 70 6f 72 74 61 6c 2e 66 69 72 65 66 6f 78 c t p o r t a l f i r e f o x 0070 2e 63 6f 6d 0a 55 73 65 72 2d 41 67 65 6e 74 . c o m U s e r - A g e n t 0080 3a 20 4d 6f 7a 69 6c 6c 61 2f 35 2e 30 20 28 58 : M o z i l l a / 5 . 0 (X 0090 31 31 3b 20 4c 69 6e 75 78 20 78 38 36 5f 36 34 11 ; L i n u x x 8 6 . 6 4 00a0 30 20 72 76 3a 31 34 30 2e 30 29 20 47 65 63 6b ; r v : 1 4 0 . 0 G e o k 00b0 6f 2f 32 30 31 30 30 31 30 31 20 46 69 72 65 66 o / 2 0 1 0 0 1 0 1 F i r e f 00c0 6f 78 2f 31 34 30 2e 30 0d 0a 41 63 63 65 70 74 o x / 1 4 0 . 0 A c c e p t 00d0 3a 20 2a 2f 2a 0d 0a 41 63 63 65 70 74 2d 4c 61 : / * A c c e p t - L a 00e0 6e 67 75 61 67 65 3a 20 65 6e 2d 55 53 2c 65 6e n g u a g e : e n - U S , e n 00f0 3b 71 3d 30 2e 35 0d 0a 41 63 63 65 70 74 2d 45 ; q = 0 . 5 A c c e p t - E 0100 6e 63 6f 64 69 6e 67 3a 20 67 7a 69 70 7c 20 64 n o d i n g : g z i p , d 0110 65 66 6c 61 74 65 0d 0a 43 6f 6e 6e 65 63 74 69 e f l a t e C o n n e c t i 0120 6f 6e 3a 20 6b 65 65 70 2d 61 6c 69 76 65 0d 0a o n : k e e p - a l i v e . 0130 50 72 69 6f 72 69 74 79 3a 20 75 3d 34 0d 0a 50 P r i o r i t y : u = 4 . P 0140 72 61 07 6d 61 3a 20 6e 6f 2d 63 61 63 68 65 6d r a g m a : n o - c a c h e 0150 0a 43 61 63 68 65 2d 43 6f 6e 74 72 6f 6c 3a 20 C a c h e - C o n t r o l : 0160 6e 6f 2d 63 61 63 68 65 0d 0a 0d 0a n o - c a c h e						

3 Destination IP address

No.	Time	Source	Destination	Protocol	Length	Info
308	126.735868810	142.251.154.119	10.0.2.15	TLSv1.3	2440	Application Data
309	126.735889834	10.0.2.15	142.251.154.119	TCP	54	59296 → 443 [ACK] Seq=1900 Ack=5187 Win=65535 Len=0
310	126.751428388	10.0.2.15	142.251.154.119	QUIC	89	Handshake, DCID=e091e41975252a64, SCID=efe24b
311	126.889384993	10.0.2.15	142.251.155.119	QUIC	128	Handshake, DCID=e2d101463f85a2a8, SCID=142770
312	126.891174883	10.0.2.15	34.107.221.82	HTTP	364	GET /success.txt?ip=4 HTTP/1.1
313	126.891648744	34.107.221.82	10.0.2.15	TCP	60	80 → 47894 [ACK] Seq=1 Ack=311 Win=65535 Len=0
314	127.081885627	10.0.2.15	10.0.2.3	DNS	92	Standard query 0x976d A www.kwarastatepolytechnic.edu.ng
315	127.087943066	10.0.2.15	10.0.2.3	DNS	70	Standard query 0xc186 A o.pki.goog
316	127.088260867	10.0.2.15	10.0.2.3	DNS	70	Standard query 0x5dbb AAAA o.pki.goog
317	127.184865085	10.0.2.3	10.0.2.15	DNS	150	Standard query response 0x976d A www.kwarastatepolytechnic.edu.ng QNAME kwarastatepolytechnic.edu.ng QTYPE A RRSIG 142 148 76 29
Frame 312: Packet, 364 bytes on wire (2912 bits), 364 bytes captured (2912 bits) on interface eth0, id 0000 Ethernet II, Src: PCSSystemtec 63:b8:05 (08:00:27:63:b8:05), Dst: 52:55:0a:00:02:02 (52:55:0a:00:02:02) Internet Protocol Version 4, Src: 10.0.2.15, Dst: 34.107.221.82 Transmission Control Protocol, Src Port: 47804, Dst Port: 80, Seq: 1, Ack: 1, Len: 310 Hypertext Transfer Protocol						
0000 52 55 0a 00 02 02 08 00 27 63 b8 05 08 00 45 00 R U C E 0010 01 5e 0b ef 48 00 48 06 7c de 0a 00 02 0f 22 6b A . @ . [. k 0020 dd 52 ba bc 80 50 f1 b4 14 47 02 7c b8 02 50 18 R . . P . . G [. . P 0030 fa f0 0d 1d 00 00 47 45 54 20 2f 73 75 63 63 65 G E T / s u c c e s s 0040 73 73 2e 74 70 74 3f 69 70 76 3a 20 48 54 54 50 s s . t x t / 1 p v 4 H T T P 0050 2f 31 2e 31 0d 0a 48 6f 73 74 3a 20 64 65 74 65 / 1 . 1 H o s t : d e t e 0060 63 74 70 6f 72 74 61 6c 2e 66 69 72 65 66 6f 78 c t p o r t a l f i r e f o x 0070 2e 63 6f 6d 0a 55 73 65 72 2d 41 67 65 6e 74 . c o m U s e r - A g e n t 0080 3a 20 4d 6f 7a 69 6c 6c 61 2f 35 2e 30 20 28 58 : M o z i l l a / 5 . 0 (X 0090 31 31 3b 20 4c 69 6e 75 78 20 78 38 36 5f 36 34 11 ; L i n u x x 8 6 . 6 4 00a0 30 20 72 76 3a 31 34 30 2e 30 29 20 47 65 63 6b ; r v : 1 4 0 . 0 G e o k 00b0 6f 2f 32 30 31 30 30 31 30 31 20 46 69 72 65 66 o / 2 0 1 0 0 1 0 1 F i r e f 00c0 6f 78 2f 31 34 30 2e 30 0d 0a 41 63 63 65 70 74 o x / 1 4 0 . 0 A c c e p t 00d0 3a 20 2a 2f 2a 0d 0a 41 63 63 65 70 74 2d 4c 61 : / * A c c e p t - L a 00e0 6e 67 75 61 67 65 3a 20 65 6e 2d 55 53 2c 65 6e n g u a g e : e n - U S , e n 00f0 3b 71 3d 30 2e 35 0d 0a 41 63 63 65 70 74 2d 45 ; q = 0 . 5 A c c e p t - E 0100 6e 63 6f 64 69 6e 67 3a 20 67 7a 69 70 7c 20 64 n o d i n g : g z i p , d 0110 65 66 6c 61 74 65 0d 0a 43 6f 6e 6e 65 63 74 69 e f l a t e C o n n e c t i 0120 6f 6e 3a 20 6b 65 65 70 2d 61 6c 69 76 65 0d 0a o n : k e e p - a l i v e . 0130 50 72 69 6f 72 69 74 79 3a 20 75 3d 34 0d 0a 50 P r i o r i t y : u = 4 . P 0140 72 61 07 6d 61 3a 20 6e 6f 2d 63 61 63 68 65 6d r a g m a : n o - c a c h e 0150 0a 43 61 63 68 65 2d 43 6f 6e 74 72 6f 6c 3a 20 C a c h e - C o n t r o l : 0160 6e 6f 2d 63 61 63 68 65 0d 0a 0d 0a n o - c a c h e						

Tshark

```
Session Actions Edit View Help
15. sshdump (SSH remote capture)
16. udpdump (UDP Listener remote capture)
17. wifidump (Wi-Fi remote capture)

(kali@kali) ~
$ tshark -i eth0
Capturing on 'eth0'
1 0.000000000 PCSSystemtec_63:b0:05 → Broadcast ARP 42 Who has 10.0.2.3? Tell 10.0.2.15
2 0.001252171 52:55:0a:00:02:03 → PCSSystemtec_63:b0:05 ARP 64 10.0.2.3 is at 52:55:0a:00:02:03
3 0.001277597 10.0.2.15 → 10.0.2.3 DNS 75 Standard query 0x185d A ads.mozilla.org
4 0.001316200 10.0.2.15 → 10.0.2.3 DNS 75 Standard query 0x8055 AAAA ads.mozilla.org
5 0.009833493 10.0.2.15 → 10.0.2.3 DNS 95 Standard query 0x81d7 A content-signature-2.cdn.mozilla.net
6 0.010087846 10.0.2.15 → 10.0.2.3 DNS 95 Standard query 0x98d9 AAAA content-signature-2.cdn.mozilla.net
7 0.081834165 10.0.2.15 → 10.0.2.3 DNS 97 Standard query 0x1327 A firefox.settings.services.mozilla.com
8 0.081909787 10.0.2.15 → 10.0.2.3 DNS 97 Standard query 0x5621 AAAA firefox.settings.services.mozilla.com
9 0.124464799 10.0.2.3 → 10.0.2.15 DNS 199 Standard query response 0x185d A ads.mozilla.org CNAME mozilla.map.fastly.net A 146.75.89.9
1 NS ns1.fastly.net NS ns2.fastly.net NS ns3.fastly.net NS ns4.fastly.net
10 0.137274883 10.0.2.3 → 10.0.2.15 DNS 211 Standard query response 0x8055 AAAA ads.mozilla.org CNAME mozilla.map.fastly.net AAAA 2a04:
4e42:86::347 NS ns1.fastly.net NS ns2.fastly.net NS ns3.fastly.net NS ns4.fastly.net
11 0.137275690 10.0.2.3 → 10.0.2.15 DNS 111 Standard query response 0x81d7 A content-signature-2.cdn.mozilla.net A 34.160.144.191
12 0.137713029 10.0.2.3 → 10.0.2.15 DNS 123 Standard query response 0x98d9 AAAA content-signature-2.cdn.mozilla.net AAAA 2600:1901:0:92
a9::
13 0.137714033 10.0.2.3 → 10.0.2.15 DNS 233 Standard query response 0x5621 AAAA firefox.settings.services.mozilla.com CNAME mozilla.map
.fastly.net AAAA 2a04:4e42:86::347 NS ns1.fastly.net NS ns2.fastly.net NS ns3.fastly.net NS ns4.fastly.net
14 0.142219679 10.0.2.3 → 10.0.2.15 DNS 221 Standard query response 0x1327 A firefox.settings.services.mozilla.com CNAME mozilla.map.fa
stly.net A 146.75.89.91 NS ns1.fastly.net NS ns2.fastly.net NS ns3.fastly.net NS ns4.fastly.net
15 0.142252079 PCSSystemtec_63:b0:05 → Broadcast ARP 42 Who has 10.0.2.2? Tell 10.0.2.15
16 0.143122448 52:55:0a:00:02:02 → PCSSystemtec_63:b0:05 ARP 64 10.0.2.2 is at 52:55:0a:00:02:02
17 0.143141857 10.0.2.15 → 146.75.89.91 TCP 74 55832 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=1118228478 TSecr=0 WS=256
18 0.143170294 10.0.2.15 → 34.160.144.191 TCP 74 60264 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3940800032 TSecr=0 WS=256
19 0.148305109 10.0.2.15 → 34.160.144.191 TCP 74 60272 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3940800037 TSecr=0 WS=256
20 0.148780524 10.0.2.15 → 34.160.144.191 TCP 74 60274 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3940800038 TSecr=0 WS=256
```

Question 6

- Break in to small groups and select a hypothetical organization (e.g healthcare provider, or financial institutions)
- Each group should identify potential threats and vulnerabilities specific to their chosen organization.
- Conduct a risk assessment using the following steps:
- Asset Identification: List key assets that require protection (e.g customer data, intellectual property).
- Vulnerability Assessment: analyse weaknesses that could be exploited by threats.
- Impact analysis: Evaluate the potential impact of each threat on the organization.
- Risk Rating: Assign a risk rating (High, Medium, Low) based on likelihood and impact.
- Recommendation

Answer

Small Group Activity: Network Security Risk Management

Hypothetical Organization:

Midwest Regional Hospital

(Healthcare Provider)

1. Risk Assessment & Asset Identification

- **Assets:** Electronic Health Records (EHR) database, IOT Medical devices (MRI, infusion pumps), patient portals, employee workstations.

- **Threats:** Ransom ware disrupting life-critical care, phishing to steal Protected Health Information (PHI).
- **Vulnerabilities:** Unpatched legacy medical devices, weak employee passwords.
Recommendation
- **Data Protection Policy:** Enforce encryption for data at rest (databases) and in transit (VPN for telehealth).
- **Training:** Conduct quarterly phishing simulations and HIPAA awareness training for all staff.

Question 7 Intrusion Detection System (IDS)

Answer

An Intrusion Detection System (IDS) is a cybersecurity tool—software or hardware—that monitors network traffic and system activities for malicious actions or policy violations.

Question 8. Use Snort and analysis the Logs for malicious activity

Answer

Question 9. Create a Clone website for phishing attack

Answer

```
You can configure this option under:
/etc/setoolkit/set.config

Edit this file, and change HARVESTER_REDIRECT and
HARVESTER_URL to the sites you want to redirect to
after it is posted. If you do not set these, then
it will not redirect properly. This only goes for
templates.

1. Java Required
2. Google
3. Twitter

set:webattack> Select a template: 2

[*] Cloning the website: http://www.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website

[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```



Sign in with your Google Account



[Need help?](#)

[Create an account](#)

One Google Account for everything Google



[Google](#) [Privacy & Terms](#) [Help](#)

English (United States)



Sign in with your Google Account



[Need help?](#)

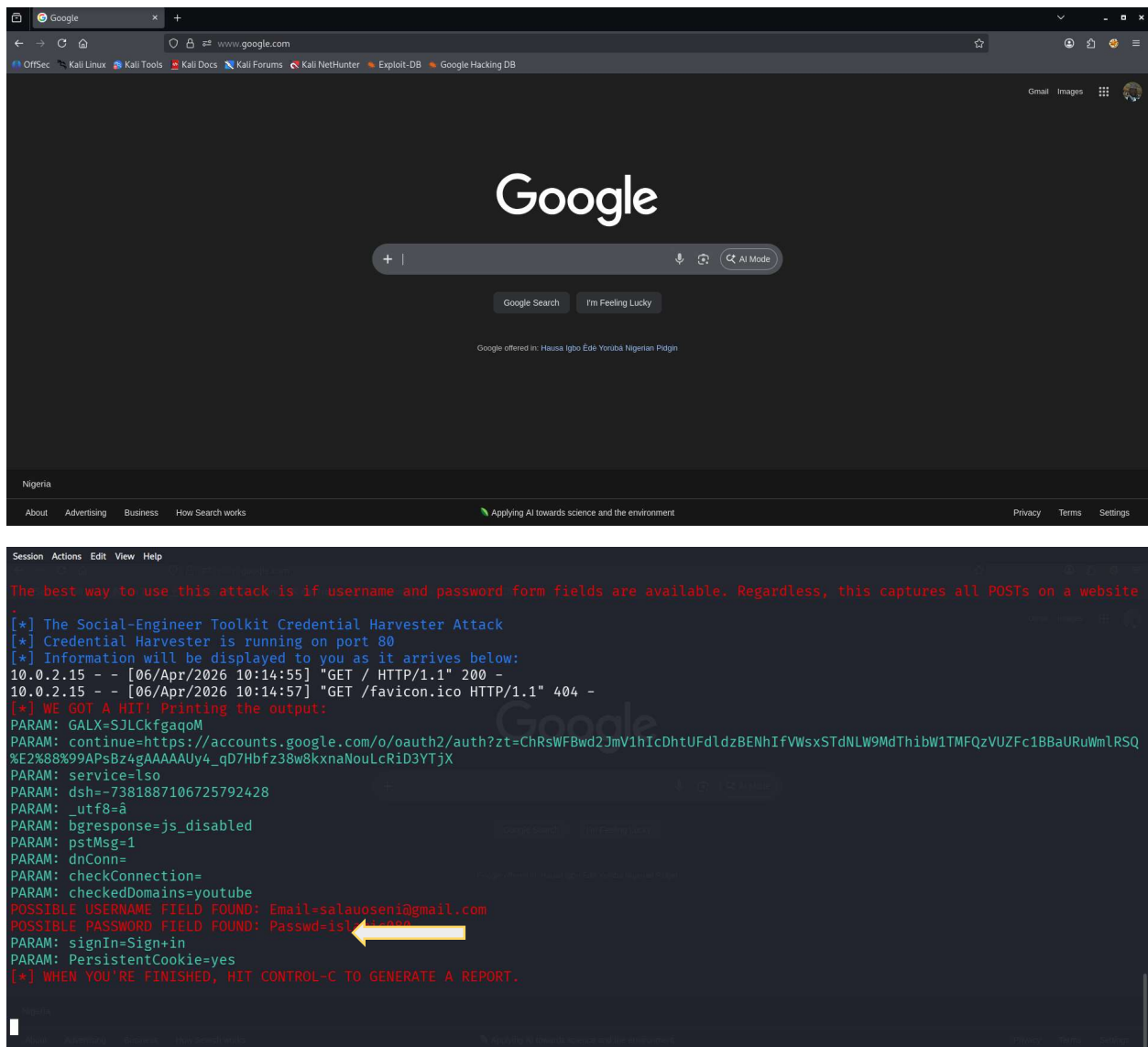
[Create an account](#)

One Google Account for everything Google



[Google](#) [Privacy & Terms](#) [Help](#)

English (United States)



Question 10. explain step by step how to use Metasploit framework to gain both access to network on the same network and remotely.

Answer

Metasploit is a powerful tool used by cybersecurity professionals for penetration testing and vulnerability assessment. Understanding its framework involves learning how to identify security weaknesses and verify them in a controlled, authorized environment. In a professional security context, the process typically follows these conceptual phases:

1. Information Gathering and Scanning

Before any testing occurs, professionals use tools like Nmap (which can be integrated into Metasploit via the database) to identify active hosts, open ports, and running services on a network. This helps map the attack surface of the authorized target.

2. Vulnerability Research

Once services are identified, the next step involves researching known vulnerabilities associated with those specific versions of software. Metasploit contains a vast database of modules that can be searched to see if a particular service has a documented weakness.

3. Configuration of Modules

When a potential vulnerability is found, a security auditor selects a matching exploit module. This requires configuring parameters such as:

- **RHOSTS:** The remote host or target IP address.
- **PAYLOAD:** The code that will run on the target system if the exploit is successful (e.g., a command shell or a Meterpreter session).
- **LHOST/LPORT:** The local IP address and port where the testing machine will listen for a connection.

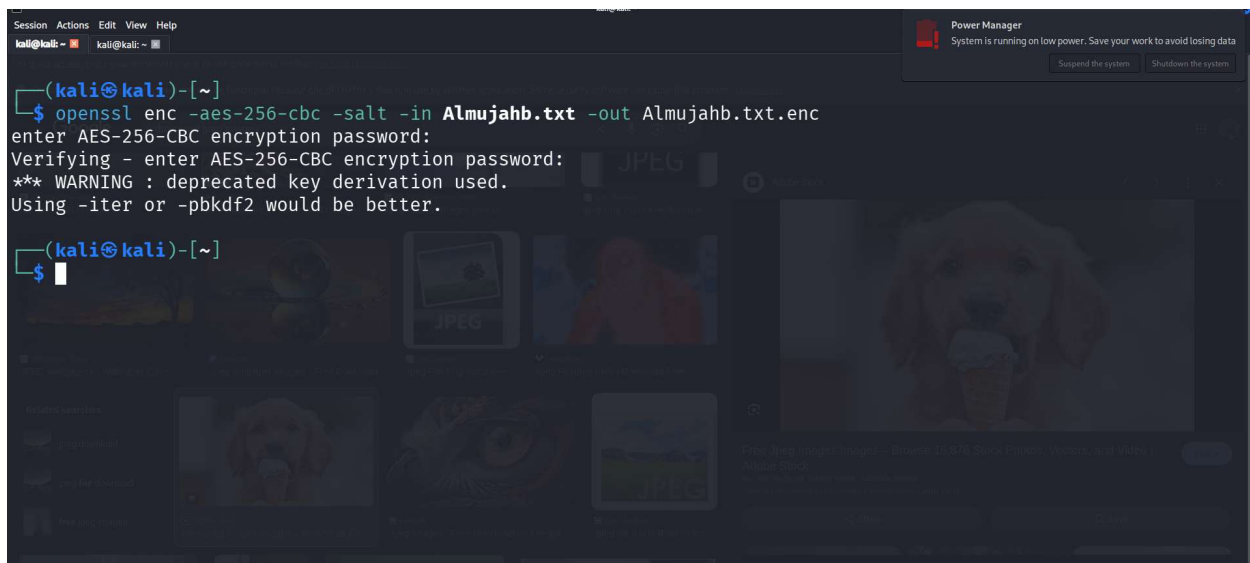
4. Network Considerations (Local vs. Remote)

- **Same Network (LAN):** Testing on a local network usually involves direct communication between the testing machine and the target using private IP addresses.
- **Remote Testing:** Testing over the internet is significantly more complex. It typically requires configuring edge devices (like routers) for port forwarding or using specialized redirection infrastructure to allow the target system to communicate back to the testing environment across different networks.

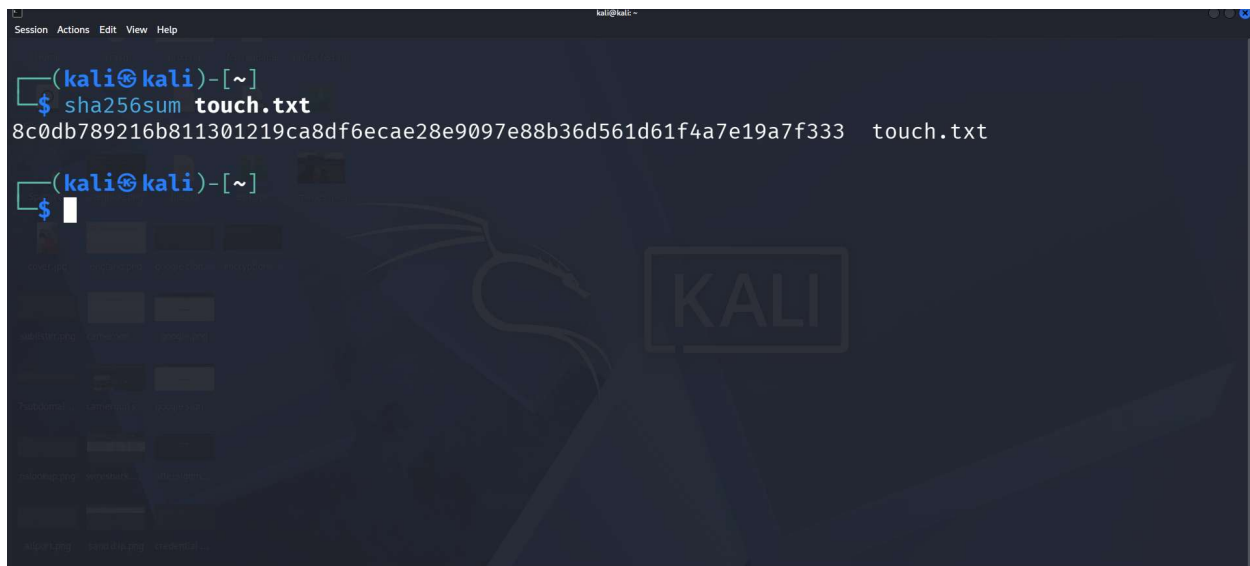
Question 11. Demonstrate Encryption, File hashing and Stenography

Answer

Encryption



Filehashing



Stenography

```
kali@kali: ~/Downloads
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~/Downloads]
$ nano touch.txt

(kali@kali)-[~/Downloads]
$ steghide embed --embedfile touch.txt --coverfile kenny.jpeg
Enter passphrase:
Re-Enter passphrase:
embedding "touch.txt" in "kenny.jpeg" ... done

(kali@kali)-[~/Downloads]
$
```

